

Ticketmaster — Production Readiness Gap Analysis

Benchmarked against ServiceNow, Zendesk, Freshservice, Jira Service Management standards (June 2025)

What We Have (Confirmed Working)

Area	Feature
Auth	JWT + refresh token, role-based access (ADMIN / DEVELOPER)
Tickets	Full CRUD, categories, subcategories, priority, status lifecycle
SLA	Assignment, breach detection, pause/resume, breach notifications
Routing	Rule-based auto-routing to team queues
Automation	Auto-close after 3 days resolved (scheduler)
AI	Keyword classifier — category + priority suggestion with confidence score
Audit	Per-field change history with actor + timestamp
Notifications	In-app bell, unread badge, mark-all-read
Security	Rate limiting on login (Bucket4j token bucket, 5/min per IP)
Comments	Internal notes vs public replies, threaded display
Dashboard	KPI scorecards, tabbed charts (status / category / priority)
Search	Client-side ticket filtering

Gap Analysis — Grouped by Severity

CRITICAL — Security Vulnerabilities (Fix Before Any Real Deployment)

1. JWT stored in localStorage — XSS attack surface

- Current: `localStorage.setItem('jwt_token', ...)` in `app.js`

- Risk: Any injected JavaScript can steal the token and fully impersonate the user
- Industry standard: HttpOnly cookies — inaccessible to JavaScript entirely
- Fix: Move token storage to HttpOnly + Secure + SameSite=Strict cookie on the server side. Eliminate all `localStorage.getItem('jwt_token')` calls from JS

2. JWT secret hardcoded in application.properties

- Current: Secret is likely a plain string in `application.properties`
- Risk: Anyone who reads the config file (or sees a commit) can forge any token for any user including admins
- Fix: Move to environment variable (`${JWT_SECRET}`), minimum 256-bit random value, never committed to git

3. No CORS policy

- Current: Spring Boot's default CORS is wide open in development
- Risk: Any malicious website can make authenticated requests on behalf of logged-in users
- Fix: Add `@CrossOrigin` restrictions or a `CorsConfigurationSource` bean that whitelists only your actual frontend origin

4. No account lockout

- Current: Rate limiting blocks IPs, but a distributed attack from many IPs bypasses it
- Risk: Credential stuffing attacks from botnets succeed
- Fix: After 10 failed attempts on a specific username (regardless of IP), lock that account for 15 minutes and require admin unlock or email verification

5. No password policy enforcement

- Current: `/api/auth/register` accepts any password including single characters
- Risk: Accounts with weak passwords are trivially compromised
- Fix: Enforce minimum 8 characters, at least one uppercase, one digit, one special character at registration time

6. Access token expiry too long

- Current: Unknown but likely set to hours or days based on typical defaults
- Industry standard: Access tokens expire in 15–60 minutes. Refresh tokens handle re-authentication silently
- Fix: Set `jwt.expiration=900000` (15 minutes) in config. Your refresh token flow already exists — use it properly

7. No auth event audit logging

- Current: Audit log records ticket changes but not login attempts, token refreshes, or logouts
 - Risk: Impossible to detect or investigate a breach after the fact
 - Fix: Log every login success, login failure, token refresh, and logout with IP + timestamp to a security_events table
-

HIGH — Core Functionality Gaps (Missing from a Usable Production System)

8. No server-side pagination

- Current: `GET /api/tickets` returns every ticket in the database in one response
- Risk: At 10,000 tickets this kills the server and the browser
- Fix: Add `Pageable` to `TicketRepository`, accept `?page=0&size=20&sort=createdAt,desc` query params, return `Page<Ticket>`

9. No server-side search

- Current: Search filters already-loaded client-side data — useless at scale
- Fix: Add `GET /api/tickets/search?q=printer` backed by a JPQL `LIKE` query on title + description

10. No ticket assignment to a specific agent

- Current: Tickets route to team queues (HARDWARE_ESCALATION_TEAM etc.) but no individual agent is assigned
- Industry standard: Every ticket has an `assignedAgent` — a specific user responsible for it
- Fix: Add `assignedAgent` field to Ticket, add assignment endpoint, show assignee in UI

11. No file attachment support

- Current: Tickets have only text description
- Industry standard: Users attach screenshots, logs, error dumps — essential for IT tickets
- Fix: `POST /api/tickets/{id}/attachments` accepting multipart upload, store to filesystem or S3, serve back via `GET`

12. No email notifications

- Current: Notifications are only visible inside the app while logged in
- Risk: Agents miss SLA breaches and new tickets if they're not actively on the dashboard
- Fix: Integrate Spring Mail (JavaMailSender), send emails on TICKET_CREATED, SLA_BREACHED, TICKET_ASSIGNED

13. No user profile management

- Current: No endpoint or UI to change your own password or view your account details
- Fix: `GET /api/users/me` (exists), `PUT /api/users/me/password` (missing), profile page in settings

14. No ticket escalation workflow

- Current: SLA breach fires a notification but nothing else happens
- Industry standard: After breach, ticket automatically escalates to a supervisor queue and changes priority to HIGH
- Fix: In `SlaManagementService`, when breach is detected, also update `assignedTo` to a supervisor queue and set priority to HIGH if not already

15. No bulk operations

- Current: Every action (acknowledge, resolve) is one ticket at a time
- Fix: Checkboxes on the ticket table, bulk-assign and bulk-status-change endpoints

MEDIUM — Analytics & Observability Gaps

16. No agent performance metrics

- Missing: Average resolution time per agent, first response time, tickets closed per day
- Industry standard: Every ITSM platform (ServiceNow, Freshservice) shows these as core KPIs
- Fix: New `GET /api/reports/agent-performance` endpoint aggregating from ticket history + timestamps

17. No resolution time tracking

- Current: We record `resolvedAt` but never display or aggregate it
- Fix: Calculate and expose `avgResolutionHours` per category and per agent

18. No ticket volume trends over time

- Current: Dashboard shows current snapshot only — no trend lines
- Fix: `GET /api/reports/volume?groupBy=day&from=2025-01-01` backed by a `createdAt` GROUP BY query, rendered as a line chart

19. No data export

- Industry standard: Managers export ticket data to Excel/CSV for reporting
- Fix: `GET /api/tickets/export?format=csv` streaming endpoint

20. No Swagger / OpenAPI documentation

- Current: API is fully undocumented
 - Fix: Add `springdoc-openapi-starter-webmvc-ui` dependency, annotate controllers — auto-generates interactive docs at `/swagger-ui.html`
-

MEDIUM — Workflow Gaps

21. No SLA escalation tiers

- Current: One SLA deadline per ticket. Breach or not.
- Industry standard: Warning at 75% of SLA time, critical at 90%, breach at 100% — each firing different actions
- Fix: Add `slaWarningAt` and `slaCriticalAt` timestamps, scheduler checks all three thresholds

22. No ticket linking / parent-child relationships

- Current: Every ticket is fully independent
- Industry standard: "This ticket is blocked by #14", or "Tickets #18, #19, #20 are sub-tasks of incident #17"
- Fix: `ticket_links` join table with `sourceId`, `targetId`, `linkType` (BLOCKS / RELATED_TO / DUPLICATES)

23. No duplicate detection

- Current: Users can raise 10 identical tickets for the same printer issue
- Fix: On `POST /api/tickets`, run keyword similarity against open tickets in the same category, warn if a likely duplicate exists

24. No SLA pause from UI

- Current: `pausedAt` field exists in the backend and the pause logic works, but there is no button in the UI to actually pause an SLA
 - Fix: Add Pause SLA button in the ticket detail modal, visible only to ADMINS
-

LOW — Quality of Life & Polish

25. No mobile responsive layout

- Current: Fixed 280px sidebar + wide table — unusable on mobile
- Fix: CSS media queries, collapsible sidebar, stacked card layout on small screens

26. No dark mode

- Current: Light mode only
- Fix: CSS variable swap on a `data-theme="dark"` body attribute, toggle button in the top bar

27. No keyboard shortcuts

- Industry standard: `N` for new ticket, `Esc` to close dialog, `?` for shortcut help
- Fix: `document.addEventListener('keydown', ...)` handler

28. No ticket filter views

- Current: Only free-text search
- Fix: Filter bar with dropdowns — filter by status, category, priority, assignee, date range

29. No "first response time" enforcement

- Industry standard: SLA has two components — time to first response AND time to resolution
- Current: Only resolution SLA is tracked
- Fix: Record `firstRespondedAt` when the first non-creator comment is posted, calculate and display the delta

30. No health check endpoint

- Fix: `GET /actuator/health` — add Spring Actuator dependency, exposes DB connectivity + disk + memory status. Required by any deployment platform (Kubernetes, Railway, Render)

Recommended Build Order

Phase F — Security Hardening (Do first — nothing else matters without this)

- F1: Move JWT to HttpOnly cookie
- F2: Externalize JWT secret to environment variable
- F3: Configure CORS properly
- F4: Add password policy + account lockout

Phase G — Scale & Core Completeness

- G1: Server-side pagination + search
- G2: Email notifications (Spring Mail)
- G3: File attachments
- G4: Ticket assignment to specific agents
- G5: SLA escalation tiers (warning + critical thresholds)

Phase H — Analytics & API

- H1: Agent performance report endpoint
- H2: Volume trend charts (time series)
- H3: CSV export
- H4: Swagger/OpenAPI docs
- H5: Spring Actuator health endpoint

Phase I — Workflow Depth

- I1: Ticket linking (blocks / related / duplicate)
- I2: Bulk operations
- I3: SLA pause button in UI
- I4: Auth event audit log

Phase J — Polish

- J1: Mobile responsive layout
- J2: Ticket filter views
- J3: Dark mode
- J4: Keyboard shortcuts

Verdict

The system is **architecturally sound and functionally complete at the core level**. The routing engine, SLA engine, audit log, AI classifier, and scheduler are things most university projects never ship at all. But three gaps currently prevent it from being called production-ready:

1. JWT in localStorage is a security vulnerability that would be flagged in any security review
2. No pagination means the system breaks under real data volume
3. No email notifications means agents have no awareness without actively watching the dashboard

Fix those three first. Everything else is depth, not survival.